Sécurité des systèmes informatiques

Attaques sur les réseaux informatiques

Abdeltouab Belbekkouche

a.belbekkouche@umontreal.ca

Université de Montréal

Contenu

- Étapes d'une attaque sur un réseau informatique
- Collecte d'informations
- Balayage
- Repérage des failles
- Intrusion
- Extension des privilèges
- Compromission
- Porte dérobée
- Nettoyage des traces

Terminologie (rappels)

- Menace (*threat*)
  - Une action susceptible de nuire
- Vulnérabilité (faille ou brèche)
  - Niveau d'exposition à une menace dans un contexte particulier
- Contre-mesure (parade)
  - L'ensemble des actions mises en œuvre en prévention de la menace
  - Pas uniquement des solutions techniques (formation, sensibilisation, ensemble de règles, etc.)

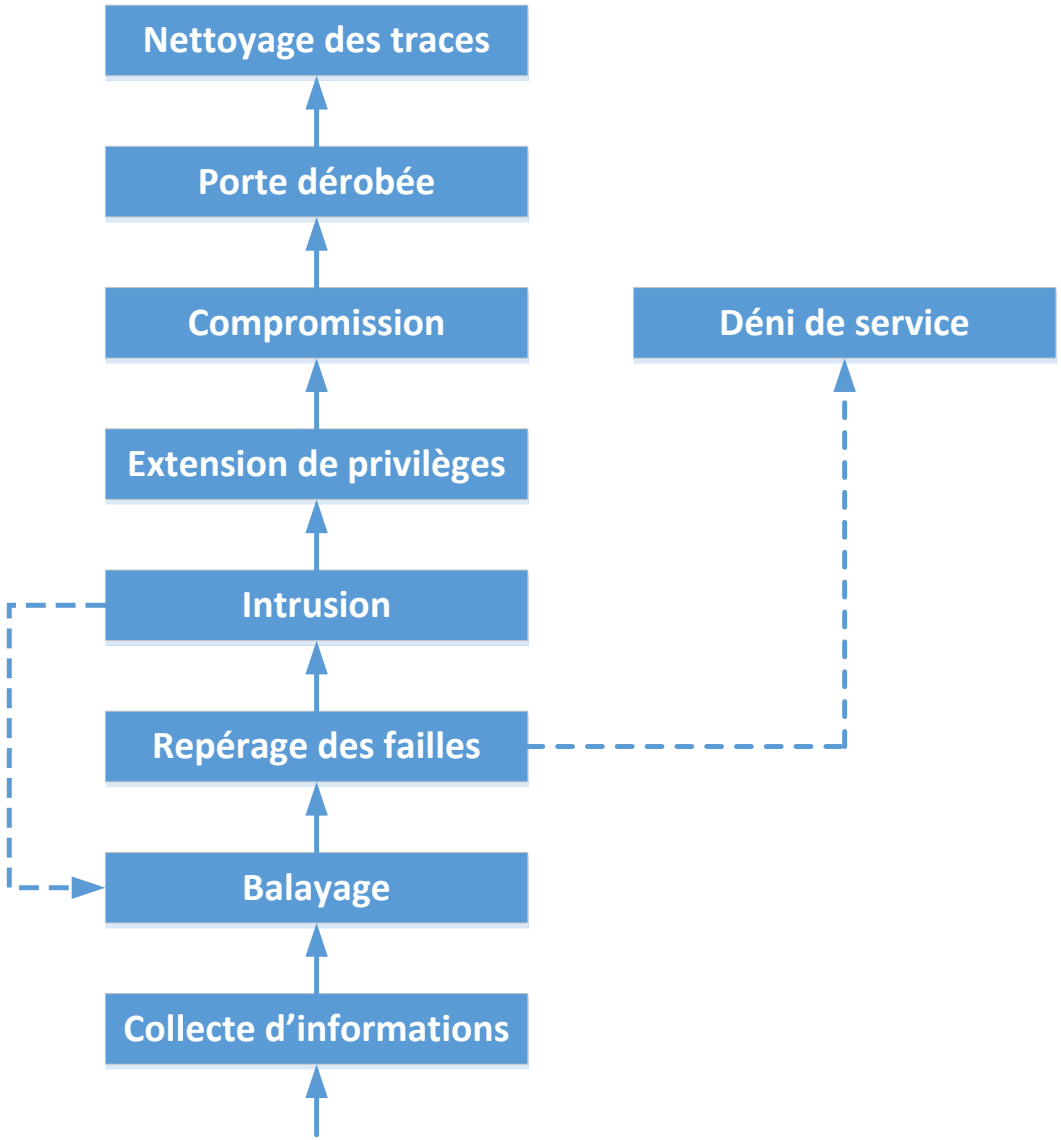
Une attaque est l'exposition d'une vulnérabilité d'un système informatique (système d'exploitation, logiciel ou même l'utilisateur) à des fins non connues par l'exploitant du système et généralement préjudiciables.

- Sur Internet, les attaques sont automatisées à raison de plusieurs attaques par seconde

Motivation des attaquants

- Obtenir un accès au système
- Voler des informations, telles que des secrets industriels ou des propriétés intellectuelles
- Recueillir des informations personnelles sur un utilisateur
- Récupérer des données bancaires
- S’informer sur une organisation
- Troubler le bon fonctionnement d’un service
- Utiliser un système comme « rebond » pour attaquer un autre système
- Utiliser les ressources d’un système (puissance de calcul, bande passante, etc.)

Étapes d'une attaque sur une réseau informatique



Collecte d'informations: quoi?

- Rassembler l'information disponible sur la cible
  - Adressage IP
  - Nom du domaine
  - Protocoles réseau
  - Services activés
  - Architecture des serveurs
  - etc.

Collecte d'informations: comment?

- Consultation des bases de données publiques
  - www.iana.net
  - www.ripe.net (Europe)
  - www.arin.net (États-Unis)
- Consultation de moteurs de recherche
  - Structure d'une entreprise
  - Nom de ses principaux produits
  - Noms de certains employés
  - Etc.
- Outils: whois, Sam Spade, Paros
- Ingénierie sociale

whois.net

umontreal.ca is already registered*

Domain Name: umontreal.ca
Registry Domain ID: D24213-CIRA
Registrar WHOIS Server: whois.ca.fury.ca
Registrar URL: https://portail.riq.qc.ca/
Updated Date: 2016-12-09T14:28:49Z
Creation Date: 2000-10-30T19:29:57Z
Registry Expiry Date: 2022-03-21T05:00:00Z
Registrar: R??seau Internet Qu??bec Inc.
Registrar IANA ID:
Registrar Abuse Contact Email:
Registrar Abuse Contact Phone:
Domain Status: ok https://icann.org/epp#OK
Registry Registrant ID: 12711979-CIRA
Registrant Name: Universit?? de Montr??al
Registrant Organization:
Registrant Street: 2900, boul ??douard-Montpetit
Registrant City: Montr??al
Registrant State/Province: QC
Registrant Postal Code: H3T1J4
Registrant Country: CA
Registrant Phone: +1.5143436111
Registrant Phone Ext: 5268
Registrant Fax: +1.5143432155
Registrant Fax Ext:
Registrant Email: inscription-dns@ti.umontreal.ca
Registry Admin ID: 15500176-CIRA

Collecte d'informations: comment? (suite)

- Fouille de poubelles (*dumpster diving*)
- Descriptions d'offres d'emploi
  - Types des systèmes utilisés
  - Savoir s'il manque des administrateurs système, etc.
- Nom et contact des responsables
- Questions des employés sur les forums
- Communiqués de presse
- Partenaires
- Réseaux sociaux

Collecte d'informations: contre-mesures

- Limiter et contrôler les informations publiques
- Responsabilité partagée entre la direction, les relations publiques et les ressources humaines
- Faire des recherches sur son organisation pour voir les informations qui filtrent
- Analyser les pages Web qui référencent le site Web de l'organisation

Balayage

- **Balayer (scanner) le réseau**
  - Déterminer à l'aide d'un outil logiciel appelé scanneur (*scanner*)
    - Les adresses IP actives sur le réseau
    - Les ports ouverts correspondant à des services accessibles
    - Les systèmes d'exploitation des machines et les versions des applications associées aux ports: **caractérisation de version**
  - L'acquisition active d'informations
    - Envoyer un grand nombre de paquets avec des en-têtes caractéristiques
    - Exemple: **Nmap**
  - L'acquisition passive d'informations
    - Analyser l'évolution des valeurs des champs sur des séries de paquets (fragments)
    - Exemple: **Siphon**

Balayage (suite)

- Lecture de bannières
  - Examiner les fichiers journaux (*logs*) des outils utilisés pour connaître les adresses IP des machines connectées au réseau et les ports ouverts sur celles-ci
  - Exemple: pour connaître la version d'un serveur HTTP

```
telnet www.commentcamarche.net 80
GET / HTTP/1.0
HTTP/1.1 200 OK
Date: Thu, 21 Mar 2002 18:22:57 GMT
Server: Apache/1.3.20 (Unix) Debian/GNU
```

Balayage: Traceroute

- Envoie de paquets **ICMP** en modifiant le champ **TTL** (*Time To Live*)
- Le routeur ou l'hôte qui reçoit un paquet avec TTL = 1 va le rejeter et envoyer un message *Time-to-live exceeded in transit* à la source
- En incrémentant la valeur du TTL, on peut obtenir la liste des routeurs qui nous séparent de la cible
- En exécutant des requêtes **traceroute** sur les adresses de l'organisation, on obtient une bonne image de la structure (cartographie) du réseau
- Contre-mesures
  - Bloquer les messages sortants de type ICMP ***Time-to-live exceeded in transit***
  - Bloquer les messages **ping** entrants
  - Bloquer les paquets avec un TTL faible

Balayage: Portscan

- Savoir quels ports sont ouverts sur un système (les « portes » ouvertes sur le système)
  - Consiste généralement à envoyer un paquet en direction de chaque port (TCP et UDP): 65536 ports possibles (32 bits)
  - On peut se contenter des ports connus
    - 80/TCP = HTTP, 443/TCP = HTTPS, 53/UDP et 53/TCP = DNS, 25/TCP = SMTP, 110/TCP = POP3, etc.
- Contre-mesures
  - Fermer les ports non utilisés
  - Désactiver les protocoles non utilisés
  - Utiliser un pare-feu *stateful*

Écoute du réseau

- Un analyseur réseau (*sniffer*) est un dispositif qui permet d'écouter le trafic d'un réseau (capturer les informations qui y circulent)
- Mode ***promiscuous***
  - Écouter tout le trafic passant par une interface (carte) réseau (Ethernet, Wi-Fi, etc.)
- Il sert généralement aux administrateurs pour diagnostiquer les problèmes sur leurs réseaux et connaître le trafic qui y circule
- Les systèmes de détection d'intrusion (IDS) sont basés sur un sniffer pour la capture des trames
- Peut également servir à une personne malveillante ayant un accès physique au réseau pour collecter des informations
  - Risque plus important sur les réseaux sans-fil (Wi-Fi, Bluetooth, etc.)

Écoute du réseau (suite)

- Exemples d'outils
  - Wireshark
  - TCP dump / WinDump
  - Microsoft Message Analyzer
- Contre-mesures
  - Utiliser des protocoles chiffrés
  - Segmenter le réseau afin de limiter la diffusion des informations
    - Préférer l'utilisation de commutateurs (*switch*) à celle des concentrateurs (*hub*)
  - Utiliser un détecteur d'analyseurs réseau (*sniffers*): sonder le réseau à la recherche de matériel utilisant le mode ***promiscuous***
  - Réduire la puissance de transmission des dispositifs sans-fil

Repérage des failles

- Déterminer si des vulnérabilités (failles) existent
- Scanneurs de vulnérabilités
  - Nessus
  - SAINT
- Bases de données de vulnérabilités
  - CVE - Common Vulnerabilities and Exposures: cve.mitre.org
  - www.securityfocus.com
  - www.insecure.org
  - Etc.

Intrusion

- Le pirate a déjà dressé une cartographie des ressources et des machines présentes sur le réseau
- Le pirate a besoin d'accéder à des comptes valides sur les machines qu'il a recensées. Plusieurs méthodes utilisées:
  - L'**ingénierie sociale**
  - La **consultation de l'annuaire** (ou des services de messagerie ou de partage de fichiers): trouver des noms d'utilisateur valides
  - L'**exploitation des vulnérabilités** des logiciels
  - Les **attaques par force brute** (*brute force cracking*): essayer, de façon automatique, différents mots de passe sur une liste de comptes

Exploit

- Un **exploit** est un programme informatique mettant en œuvre l'exploitation d'une vulnérabilité publiée ou non
- Chaque exploit est spécifique à une version d'une application, car il permet d'en exploiter les failles
- Types d'exploits
  - Extension des privilèges
    - Permettre de contrôler les programmes exécutés avec les privilèges d'administrateur
  - Provocation d'une erreur système
- Souvent écrit en langage C ou en Perl

Extension des privilèges

- Le pirate va chercher à **élargir ses privilèges** après avoir obtenu un ou plusieurs accès au réseau en se connectant à un ou plusieurs comptes
- Accès ***root***: super-utilisateur ou superadministrateur ➔ **compromission**
- Le pirate a alors la possibilité d'examiner le réseau à la recherche d'informations supplémentaires
  - Installer un analyseur réseau (*sniffer*)
  - Attaquer d'autres comptes (ou machines, serveurs, etc.) dans le réseau

Compromission et porte dérobée

- Compromission
  - Exploit des relations d'approbation existantes entre les différentes machines
  - Usurpation d'identité (*spoofing*)
  - Permettre au pirate de s'introduire dans des réseaux privilégiés auxquels la machine compromise a accès
- Porte dérobée
  - Installer une application afin de créer une faille de sécurité
    - Porte dérobée ou trappe (*backdoor*)

Nettoyage des traces

- Effacer les traces de passage de l'intrus des machines dans lesquelles il s'est introduit
  - Supprimer les fichiers qu'il avait créés
  - Nettoyer les journaux des activités (*logs*)
- Installer un *rootkit*
  - Remplacer les outils d'administration du système par des versions modifiées pour masquer la présence de l'intrus